



VAPT TASK 01

Intern: Aliya Ansari

Assessment date: 30-Oct-2025

Environment: Kali VM (192.168.0.205) attacking Metasploitable2 VM (192.168.0.139)

Contents

1. Executive summary
 2. Scope & objectives
 3. Tools & environment
 4. Methodology (step-by-step)
 5. Findings (detailed, evidence-linked)
 6. Risk assessment & prioritisation
 7. Proofs & reproduction steps (what I ran)
 8. Remediation & mitigation — actionable checklist
 9. Appendix: raw outputs and recommended screenshot placement
 10. Notes & learning outcomes
-

1. Executive summary

This assessment targeted a lab instance (Metasploitable2) to exercise vulnerability discovery and documentation using only free/open-source tools. The host exposes multiple legacy services and clear misconfigurations (anonymous FTP, SMB null session, exposed phpinfo and phpMyAdmin, outdated Apache/MySQL/Samba, open distcc and RMI). These present high-risk vectors in a real network. The goal of this report is to present clear findings, prioritized remediation, and evidence so the results are reproducible and understandable.

Overall risk (lab): High — multiple critical and high severity issues.

2. Scope & objectives

- **Target:** 192.168.0.139 (Metasploitable2)
 - **Attacker:** Kali VM (192.168.0.205)
 - **Allowed activities:** Non-destructive enumeration, safe verification (directory listing, login attempts, non-exploiting uploads), service probing, and documentation. No destructive exploitation unless explicitly requested.
-



- **Deliverable:** This PDF-formatted report with evidence attachments and screenshots.
-

3. Tools & environment

- Kali Linux (attacker): nmap (v7.95), dirb, nikto, curl, ftp, smbclient, enum4linux, mysql client, psql, nc, showmount, Nmap NSE (rmi-dumpregistry, vuln), and standard shell utilities.
- Target VM: Metasploitable2 — intentionally vulnerable training image.

All outputs saved as .txt files; recommended screenshots saved as .png in screenshots/.

4. Methodology (concise step-by-step)

1. Reconnaissance: ICMP + Full TCP port scan. (ping, nmap -p-)
 2. Service/version detection: targeted nmap -sV -sC and OS detection.
 3. Web enumeration: curl (headers + index), dirb directory brute-force, nikto scan.
 4. SMB/FTP/DB checks: smbclient, enum4linux, anonymous FTP login & upload test, MySQL/Postgres connection attempts.
 5. Service-specific checks: rmi-dumpregistry on 1099, showmount for NFS, nc for banners.
 6. Vulnerability scripts: nmap --script vuln on important services.
 7. Documenting & saving outputs; take screenshots for each major step and collect .txt outputs as appendices.
-

5. Findings

Finding A — Multiple legacy services exposed

Summary: Host runs multiple outdated services: Apache 2.2.8, PHP 5.2.4, MySQL 5.0.51a, Samba 3.0.20, vsftpd 2.3.4, distccd, RMI (1099), telnet, VNC.

Evidence files: nmap_full_tcp_192-168-0-139.txt, nmap_svcs_192-168-0-139.txt, nmap_os_192-168-0-139.txt



Risk: High. Old versions often have public CVEs and lack modern TLS/auth.

Recommendation: Patch/upgrade or isolate the services; use hostname-based/ACL restrictions and firewall rules.

Finding B — Web: phpinfo & phpMyAdmin exposed; missing security headers; TRACE method enabled

Summary: phpinfo.php and phpMyAdmin directories are publicly reachable; server missing X-Frame-Options & X-Content-Type-Options headers; HTTP TRACE enabled.

Evidence files/screenshots: 01_http_headers.txt, 01_http_index.html, 02_dirb_192-168-0-139.txt, 03_nikto_192-168-0-139.txt; screenshots: screenshots/nikto.png, screenshots/dirb.png, screenshots/http_headers.png.

Risk: High (information disclosure & admin panels exposed).

Recommendation: Remove phpinfo, restrict phpMyAdmin by IP or auth, add security headers, disable TRACE, disable directory indexing.

Finding C — FTP allows anonymous login (listing) and exposes vsftpd banner

Summary: Anonymous login accepted; directory listing works. Upload attempt returned 553 Could not create file (upload denied), but anonymous read is sufficient for information disclosure.

Evidence: 04_ftp_banner.txt, 04_ftp_session.txt, 04_ftp_upload.txt; screenshot: screenshots/ftp_session.png.

Risk: High. If write is enabled in other setups, attackers can upload malicious files.

Remediation: Disable anonymous FTP; require user accounts; update vsftpd; restrict to necessary hosts.

Finding D — SMB: anonymous/null sessions and public share (tmp)

Summary: enum4linux and smbclient show anonymous/null session allowed, users enumerated (root, msfadmin, mysql, etc.), and //192.168.0.139/tmp is listable.

Evidence: 05_enum4linux_192-168-0-139.txt, 05_smbclient_list.txt; screenshot: screenshots/enum4linux.png.

Risk: Critical — allows info disclosure, possible file drop/retrieval.

Remediation: Disable null sessions (restrict anonymous), remove public shares, require authentication, upgrade Samba and enable SMB signing.

Finding E — Databases reachable; TLS mismatch and legacy versions

Summary: MySQL 5.0 responds but client must use --skip-ssl due to TLS mismatch; Postgres refused with SSL error then password auth failed (indicating service online but password protected).



Evidence: 06_mysql_attempt.txt, 06_mysql_databases.txt, 07_pg_attempt.txt; screenshot: screenshots/mysql_connect.png.

Risk: High. Old DB versions; insecure TLS and weak authentication raise data exfiltration concerns.

Remediation: Upgrade DBs, enforce TLS with modern ciphers, restrict access, enforce strong DB user passwords and remove default accounts.

Finding F — RMI (1099) and distccd (3632) present

Summary: RMI registry present (1099 identified as GNU Classpath grmiregistry) and distccd open — both are known vectors for remote code loading or remote code execution on misconfigured/old servers.

Evidence: 09_rmi_nmap.txt, 08_distcc_banner.txt; screenshot: screenshots/rmi_nmap.png.

Risk: High — possible RCE in vulnerable configurations.

Remediation: Disable/RPC restrict these services or upgrade and configure to not allow arbitrary class loading.

Finding G — Telnet & VNC open

Summary: Plaintext telnet (23) and VNC (5900) are reachable. Telnet showed banner; VNC shows service reachable.

Evidence: 11_telnet_banner.txt, 12_vnc_banner.txt.

Risk: High for credentials and remote control.

Remediation: Replace telnet with SSH; restrict VNC; require strong authentication and network segmentation.

6. Risk assessment & prioritisation (quick matrix)

Priority levels: P1 = Fix immediately; P2 = High priority; P3 = Medium; P4 = Low.

Finding	Priority	Rationale
SMB null session + tmp share	P1	Public enumeration, file access, and outdated Samba (RCE CVEs)
Exposed phpMyAdmin & phpinfo	P1	Admin interface and config disclosure
Anonymous FTP	P1	Information disclosure + possible upload risk
Outdated DBs (MySQL/Postgres)	P2	Old versions and TLS issues
distccd & RMI	P2	Known RCE vectors if misconfigured



Finding	Priority	Rationale
Telnet/VNC/X11 enabled	P2	Plaintext auth / remote control
Directory indexing & missing headers	P3	Information leakage; lower exploitability alone

7. Proofs & reproduction steps (what I ran)

Include these command lines and reference the exact saved file names. Add terminal screenshots at each step.

1. `ping -c 3 192.168.0.139` →

```
(kali㉿kali)-[~]
└─$ ping -c 3 192.168.0.139
PING 192.168.0.139 (192.168.0.139) 56(84) bytes of data.
64 bytes from 192.168.0.139: icmp_seq=1 ttl=64 time=3.96 ms
64 bytes from 192.168.0.139: icmp_seq=2 ttl=64 time=0.464 ms
64 bytes from 192.168.0.139: icmp_seq=3 ttl=64 time=0.898 ms

— 192.168.0.139 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2028ms
rtt min/avg/max/mdev = 0.464/1.775/3.963/1.557 ms
```



2. `sudo nmap -sS -Pn -p- -T4 192.168.0.139 -oN nmap_full_tcp_192-168-0-139.txt` → (full port list)

```
kali@kali: ~  
Session Actions Edit View Help  
└─(kali@kali)-[~]  
$ sudo nmap -sS -Pn -p- -T4 192.168.0.139 -oN nmap_full_tcp_192-168-0-139.txt  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-30 11:29 EDT  
Nmap scan report for metasploitable (192.168.0.139)  
Host is up (0.0025s latency).  
Not shown: 65505 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
53/tcp    open  domain  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
512/tcp   open  exec  
513/tcp   open  login  
514/tcp   open  shell  
1099/tcp  open  rmiregistry  
1524/tcp  open  ingreslock  
2049/tcp  open  nfs  
2121/tcp  open  ccproxy-ftp  
3306/tcp  open  mysql  
3632/tcp  open  distccd  
5432/tcp  open  postgresql  
5900/tcp  open  vnc  
6000/tcp  open  X11  
6667/tcp  open  irc  
6697/tcp  open  ircs-u  
8009/tcp  open  ajp13  
8180/tcp  open  unknown  
8787/tcp  open  msgsrvr  
39932/tcp open  unknown  
44168/tcp open  unknown  
44754/tcp open  unknown  
46516/tcp open  unknown  
MAC Address: 00:0C:29:EF:05:E4 (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 8.09 seconds
```

```
File Edit Search View Document Help  
~nmap_full_tcp_192-168-0-139.txt [Read Only] - Mousepad  
1 # Nmap 7.95 scan initiated Thu Oct 30 11:29:54 2025 as: /usr/lib/nmap/nmap -sS -Pn -p- -T4 -oN nmap_full_tcp_192-168-0-139.txt 192.168.0.139  
2 Nmap scan report for metasploitable (192.168.0.139)  
3 Host is up (0.0025s latency).  
4 Not shown: 65505 closed tcp ports (reset)  
5 PORT      STATE SERVICE  
6 21/tcp    open  ftp  
7 22/tcp    open  ssh  
8 23/tcp    open  telnet  
9 25/tcp    open  smtp  
10 53/tcp    open  domain  
11 80/tcp    open  http  
12 111/tcp   open  rpcbind  
13 139/tcp   open  netbios-ssn  
14 445/tcp   open  microsoft-ds  
15 512/tcp   open  exec  
16 513/tcp   open  login  
17 514/tcp   open  shell  
18 1099/tcp  open  rmiregistry  
19 1524/tcp  open  ingreslock  
20 2049/tcp  open  nfs  
21 2121/tcp  open  ccproxy-ftp  
22 3306/tcp  open  mysql  
23 3632/tcp  open  distccd  
24 5432/tcp  open  postgresql  
25 5900/tcp  open  vnc  
26 6000/tcp  open  X11  
27 6667/tcp  open  irc  
28 6697/tcp  open  ircs-u  
29 8009/tcp  open  ajp13  
30 8180/tcp  open  unknown  
31 8787/tcp  open  msgsrvr  
32 39932/tcp open  unknown  
33 44168/tcp open  unknown  
34 44754/tcp open  unknown  
35 46516/tcp open  unknown  
36 MAC Address: 00:0C:29:EF:05:E4 (VMware)  
37
```



3. `sudo nmap -sV -sC -p22,80,139,445,3306,8080 192.168.0.139 -oN nmap_svcs_192-168-0-139.txt` → (service details)

```
(kali@kali)~$ sudo nmap -sV -sC -p22,80,139,445,3306,8080 192.168.0.139 -oN nmap_svcs_192-168-0-139.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-30 11:30 EDT
Nmap Scan report for metasploitable (192.168.0.139)
Host is up (0.0011s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Thread ID: 10
|_ Capabilities flags: 43564
|_ Some Capabilities: SupportsTransactions, SupportsCompression, ConnectWithDatabase, SwitchToSSLAfterHandshake, Support41Auth, LongColumnFlag, Speaks41Pr
otocolNew
|_ Status: Autocommit
|_ Salt: V7t0LT=uX9QmP)wAlo8f
8080/tcp  closed http-proxy
MAC Address: 00:0C:29:EF:05:E4 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb-security-mode:
|_   account_used: guest
|_   authentication_level: user
|_   challenge_response: supported
|_   message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: 1h58m28s, deviation: 2h49m42s, median: -1m31s
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ smb-os-discovery:
|_   OS: Unix (Samba 3.0.20-Debian)

Session Actions Edit View Help
|_ Capabilities flags: 43564
|_ Some Capabilities: SupportsTransactions, SupportsCompression, ConnectWithDatabase, SwitchToSSLAfterHandshake, Support41Auth, LongColumnFlag, Speaks41Pr
otocolNew
|_ Status: Autocommit
|_ Salt: V7t0LT=uX9QmP)wAlo8f
8080/tcp closed http-proxy
MAC Address: 00:0C:29:EF:05:E4 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb-security-mode:
|_   account_used: guest
|_   authentication_level: user
|_   challenge_response: supported
|_   message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: 1h58m28s, deviation: 2h49m42s, median: -1m31s
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ smb-os-discovery:
|_   OS: Unix (Samba 3.0.20-Debian)
|_   Computer name: metasploitable
|_   NetBIOS computer name:
|_   Domain name: localdomain
|_   FQDN: metasploitable.localdomain
|_   System time: 2025-10-30T11:28:57-04:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.98 seconds

~/nmap_svcs_192-168-0-139.txt [Read Only] - Mousepad

1 # Nmap 7.95 scan initiated Thu Oct 30 11:30:16 2025 as: /usr/lib/nmap/nmap -sV -sC -p22,80,139,445,3306,8080 -oN nmap_svcs_192-168-0-139.txt 192.168.0.139
2 Nmap scan report for metasploitable (192.168.0.139)
3 Host is up (0.0011s latency).
4
5 PORT      STATE SERVICE      VERSION
6 22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
7 | ssh-hostkey:
8 |_ 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
9 |_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
10 80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
11 |_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
12 |_ http-title: Metasploitable2 - Linux
13 139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
14 445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
15 3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
16 |_ mysql-info:
17 |_ Protocol: 10
18 |_ Version: 5.0.51a-3ubuntu5
19 |_ Thread ID: 10
20 |_ Capabilities flags: 43564
21 |_ Some Capabilities: SupportsTransactions, SupportsCompression, ConnectWithDatabase, SwitchToSSLAfterHandshake, Support41Auth, LongColumnFlag,
Speaks41ProtocolNew
22 |_ Status: Autocommit
23 |_ Salt: V7t0LT=uX9QmP)wAlo8f
24 8080/tcp  closed http-proxy
25 MAC Address: 00:0C:29:EF:05:E4 (VMware)
26 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
27
28 Host script results:
29 |_ smb-security-mode:
30 |_   account_used: guest
31 |_   authentication_level: user
32 |_   challenge_response: supported
33 |_   message_signing: disabled (dangerous, but default)
34 |_ clock-skew: mean: 1h58m28s, deviation: 2h49m42s, median: -1m31s
35 |_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
36 |_ smb2-time: Protocol negotiation failed (SMB2)
37 |_ smb-os-discovery:
38 |_   OS: Unix (Samba 3.0.20-Debian)
39 |_   Computer name: metasploitable
40 |_   NetBIOS computer name:
41 |_   Domain name: localdomain
42 |_   FQDN: metasploitable.localdomain
43 |_   System time: 2025-10-30T11:28:57-04:00
```



4. `sudo nmap -O 192.168.0.139 -oN nmap_os_192-168-0-139.txt` → (OS detection)

```
(kali@kali)~$ sudo nmap -O 192.168.0.139 -oN nmap_os_192-168-0-139.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-30 11:30 EDT
Nmap scan report for metasploitable (192.168.0.139)
Host is up (0.00069s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:EF:05:E4 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.73 seconds
```

~/nmap_os_192-168-0-139.txt (Read Only) - Mousepad

File Edit Search View Document Help

nmap_full_tcp_192-168-0-139.txt x nmap_svcs_192-168-0-139.txt x nmap_os_192-168-0-139.txt x

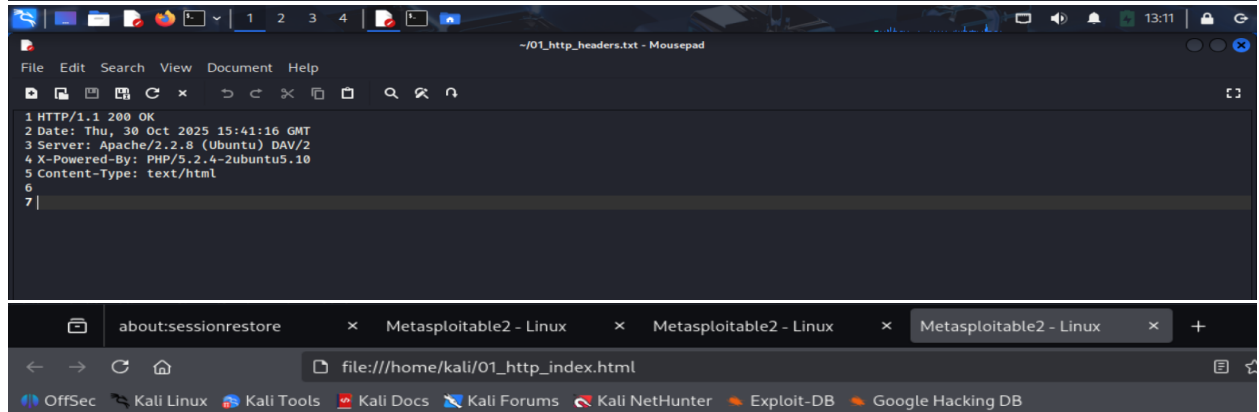
```
1# Nmap 7.95 scan initiated Thu Oct 30 11:30:42 2025 as: /usr/lib/nmap/nmap -O -oN nmap_os_192-168-0-139.txt 192.168.0.139
2 Nmap scan report for metasploitable (192.168.0.139)
3 Host is up (0.00069s latency).
4 Not shown: 977 closed tcp ports (reset)
5 PORT      STATE SERVICE
6 21/tcp    open  ftp
7 22/tcp    open  ssh
8 23/tcp    open  telnet
9 25/tcp    open  smtp
10 53/tcp    open  domain
11 80/tcp    open  http
12 111/tcp   open  rpcbind
13 139/tcp   open  netbios-ssn
14 445/tcp   open  microsoft-ds
15 512/tcp   open  exec
16 513/tcp   open  login
17 514/tcp   open  shell
18 1099/tcp  open  rmiregistry
19 1524/tcp  open  ingreslock
20 2049/tcp  open  nfs
21 2121/tcp  open  ccproxy-ftp
22 3306/tcp  open  mysql
23 5432/tcp  open  postgresql
24 5900/tcp  open  vnc
25 6000/tcp  open  X11
26 6667/tcp  open  irc
27 8009/tcp  open  ajp13
28 8180/tcp  open  unknown
29 MAC Address: 00:0C:29:EF:05:E4 (VMware)
30 Device type: general purpose
31 Running: Linux 2.6.X
32 OS CPE: cpe:/o:linux:linux_kernel:2.6
33 OS details: Linux 2.6.9 - 2.6.33
34 Network Distance: 1 hop
```



5. `curl -I http://192.168.0.139/ > 01_http_headers.txt` and `curl http://192.168.0.139/ > 01_http_index.html`

```
(kali@kali)-[~]
$ curl -I http://192.168.0.139/ > 01_http_headers.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           0         0     0           0          0      0      0      0
           0         0     0           0          0      0      0      0

(kali@kali)-[~]
$ curl http://192.168.0.139/ > 01_http_index.html
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           0         0     0           0          0      0      0      0
100    891    100    891      0     0    62693      0   --:--:--   --:--:--   --:--:--   63642
```



Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

6. `dirb http://192.168.0.139 /usr/share/wordlists/dirb/common.txt -o 02_dirb_192-168-0-139.txt`

```
kali@kali: ~
$ dirb http://192.168.0.139 /usr/share/wordlists/dirb/common.txt -o 02_dirb_192-168-0-139.txt

DIRB v2.22
By The Dark Raver

OUTPUT_FILE: 02_dirb_192-168-0-139.txt
START_TIME: Thu Oct 30 11:44:45 2025
URL_BASE: http://192.168.0.139/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.0.139/ ---
+ http://192.168.0.139/cgi-bin/ (CODE:403|SIZE:294)
=> DIRECTORY: http://192.168.0.139/dav/
+ http://192.168.0.139/index (CODE:200|SIZE:891)
+ http://192.168.0.139/index.php (CODE:200|SIZE:891)
+ http://192.168.0.139/phpinfo (CODE:200|SIZE:48077)
+ http://192.168.0.139/phpinfo.php (CODE:200|SIZE:48089)
=> DIRECTORY: http://192.168.0.139/phpMyAdmin/
+ http://192.168.0.139/server-status (CODE:403|SIZE:299)
=> DIRECTORY: http://192.168.0.139/test/
=> DIRECTORY: http://192.168.0.139/twiki/

--- Entering directory: http://192.168.0.139/dav/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.0.139/phpMyAdmin/ ---
+ http://192.168.0.139/phpMyAdmin/calendar (CODE:200|SIZE:4145)
+ http://192.168.0.139/phpMyAdmin/changelog (CODE:200|SIZE:74593)
+ http://192.168.0.139/phpMyAdmin/changelog (CODE:200|SIZE:40540)
=> DIRECTORY: http://192.168.0.139/phpMyAdmin/contib/
+ http://192.168.0.139/phpMyAdmin/docs (CODE:200|SIZE:4583)
+ http://192.168.0.139/phpMyAdmin/error (CODE:200|SIZE:1863)
+ http://192.168.0.139/phpMyAdmin/export (CODE:200|SIZE:4145)
+ http://192.168.0.139/phpMyAdmin/favicon.ico (CODE:200|SIZE:18902)
```



```
Session Actions Edit View Help
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.0.139/phpMyAdmin/setup/ ---
+ http://192.168.0.139/phpMyAdmin/setup/config (CODE:303|SIZE:1370)
=> DIRECTORY: http://192.168.0.139/phpMyAdmin/setup/frames/
+ http://192.168.0.139/phpMyAdmin/setup/index (CODE:200|SIZE:8617)
+ http://192.168.0.139/phpMyAdmin/setup/index.php (CODE:200|SIZE:8625)
=> DIRECTORY: http://192.168.0.139/phpMyAdmin/setup/lib/
+ http://192.168.0.139/phpMyAdmin/setup/scripts (CODE:200|SIZE:21967)
+ http://192.168.0.139/phpMyAdmin/setup/styles (CODE:200|SIZE:6218)

--- Entering directory: http://192.168.0.139/phpMyAdmin/test/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.0.139/phpMyAdmin/themes/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.0.139/twiki/bin/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.0.139/twiki/lib/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.0.139/twiki/pub/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.0.139/phpMyAdmin/setup/frames/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.0.139/phpMyAdmin/setup/lib/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

END_TIME: Thu Oct 30 11:44:59 2025
DOWNLOADED: 18448 - FOUND: 42

~/02_dirb_192-168-0-139.txt - Mousepad
File Edit Search View Document Help

01_http_headers.txt x 02_dirb_192-168-0-139.txt x

1 |
2 |
3 DIRB v2.22
4 By The Dark Raver
5 |
6 |
7 OUTPUT_FILE: 02_dirb_192-168-0-139.txt
8 START_TIME: Thu Oct 30 11:44:45 2025
9 URL_BASE: http://192.168.0.139/
10 WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt
11 |
12 |
13 |
14 GENERATED WORDS: 4612
15 |
16 --- Scanning URL: http://192.168.0.139/ ---
17 + http://192.168.0.139/cgi-bin/ (CODE:403|SIZE:294)
18 => DIRECTORY: http://192.168.0.139/dav/
19 + http://192.168.0.139/index (CODE:200|SIZE:891)
20 + http://192.168.0.139/index.php (CODE:200|SIZE:891)
21 + http://192.168.0.139/phpinfo (CODE:200|SIZE:48077)
22 + http://192.168.0.139/phpinfo.php (CODE:200|SIZE:48089)
23 => DIRECTORY: http://192.168.0.139/phpMyAdmin/
24 + http://192.168.0.139/server-status (CODE:403|SIZE:299)
25 => DIRECTORY: http://192.168.0.139/test/
26 => DIRECTORY: http://192.168.0.139/twiki/
27 |
28 --- Entering directory: http://192.168.0.139/dav/ ---
29 (!) WARNING: Directory IS LISTABLE. No need to scan it.
30 (Use mode '-w' if you want to scan it anyway)
31 |
32 --- Entering directory: http://192.168.0.139/phpMyAdmin/ ---
33 + http://192.168.0.139/phpMyAdmin/calendar (CODE:200|SIZE:4145)
34 + http://192.168.0.139/phpMyAdmin/changelog (CODE:200|SIZE:74593)
35 + http://192.168.0.139/phpMyAdmin/faq (CODE:200|SIZE:10519)
```



7. nikto -h http://192.168.0.139 -o 03_nikto_192-168-0-139.txt

```
kali@kali: ~  
Session Actions Edit View Help  
$ nikto -h http://192.168.0.139 -o 03_nikto_192-168-0-139.txt  
- Nikto v2.5.0  
+ Target IP: 192.168.0.139  
+ Target Hostname: 192.168.0.139  
+ Target Port: 80  
+ Start Time: 2025-10-30 11:46:26 (GMT-4)  
+ Server: Apache/2.2.8 (Ubuntu) DAV/2  
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.  
+ /index: Uncommon header 'tcn' found, with contents: list.  
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.  
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing  
+ /phpinfo.php: Output from the phpinfo() function was found.  
+ /doc/: Directory indexing found.  
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678  
+ /%PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184  
+ /%PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184  
+ /%PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184  
+ /%PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184  
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ /test/: Directory indexing found.  
+ /test/: This might be interesting.  
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552  
+ /icons/: Directory indexing found.  
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/  
+ /phpMyAdmin/: phpMyAdmin directory found.
```

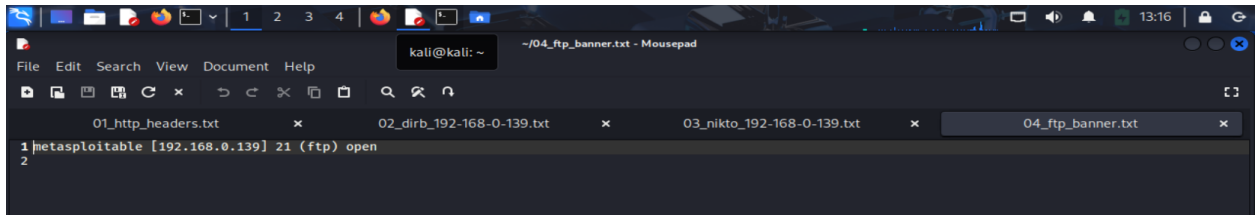
re the mouse pointer inside or press Ctrl+G.

```
03_nikto_192-168-0-139.txt - Mousepad  
File Edit Search View Document Help  
01_http_headers.txt x 02_dirb_192-168-0-139.txt x 03_nikto_192-168-0-139.txt x  
1- Nikto v2.5.0/  
2+ Target Host: 192.168.0.139  
3+ Target Port: 80  
4+ GET /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.  
5+ GET /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options:  
6+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME  
type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
7+ HEAD Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.  
8+ GET /index: Uncommon header 'tcn' found, with contents: list.  
9+ GET /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for  
'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275:  
10+ KNOMUGVX /: Web Server returns a valid response with junk HTTP methods which may cause false positives.  
11+ TRACE /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing:  
12+ GET /phpinfo.php: Output from the phpinfo() function was found.  
13+ GET /doc/: Directory indexing found.  
14+ GET /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: CVE-1999-0678:  
15+ GET /%PHPE9568F35-D428-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY  
strings. See: OSVDB-12184:  
16+ GET /%PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY  
strings. See: OSVDB-12184:  
17+ GET /%PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY  
strings. See: OSVDB-12184:  
18+ GET /%PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY  
strings. See: OSVDB-12184:  
19+ GET /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
20+ GET /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9  
12:24:00 2008. See: CVE-2003-1418:  
21+ GET /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
22+ GET /test/: Directory indexing found.  
23+ GET /test/: This might be interesting.  
24+ GET /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552:  
25+ GET /icons/: Directory indexing found.  
26+ GET /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/  
27+ GET /phpMyAdmin/: phpMyAdmin directory found.  
28+ GET /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
```

re the mouse pointer inside or press Ctrl+G.

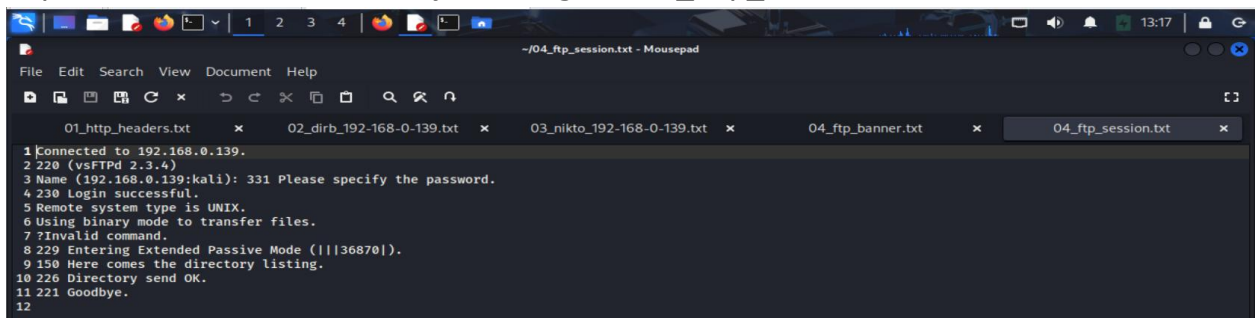


8. `nc -vz 192.168.0.139 21 > 04_ftp_banner.txt 2>&1`



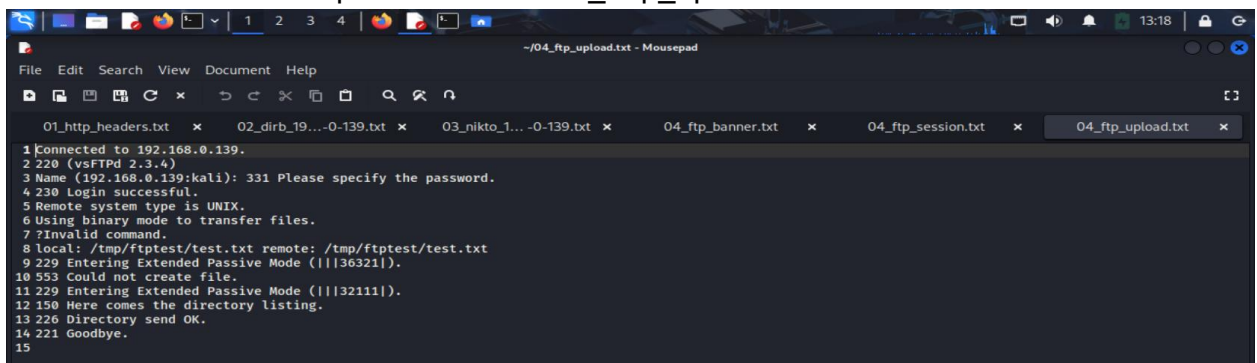
```
kali@kali: ~  
~/04_ftp_banner.txt - Mousepad  
File Edit Search View Document Help  
01_http_headers.txt x 02_dirb_192-168-0-139.txt x 03_nikto_192-168-0-139.txt x 04_ftp_banner.txt x  
1 |metasploitable [192.168.0.139] 21 (ftp) open  
2
```

9. `ftp -v 192.168.0.139 anonymous login → 04_ftp_session.txt`



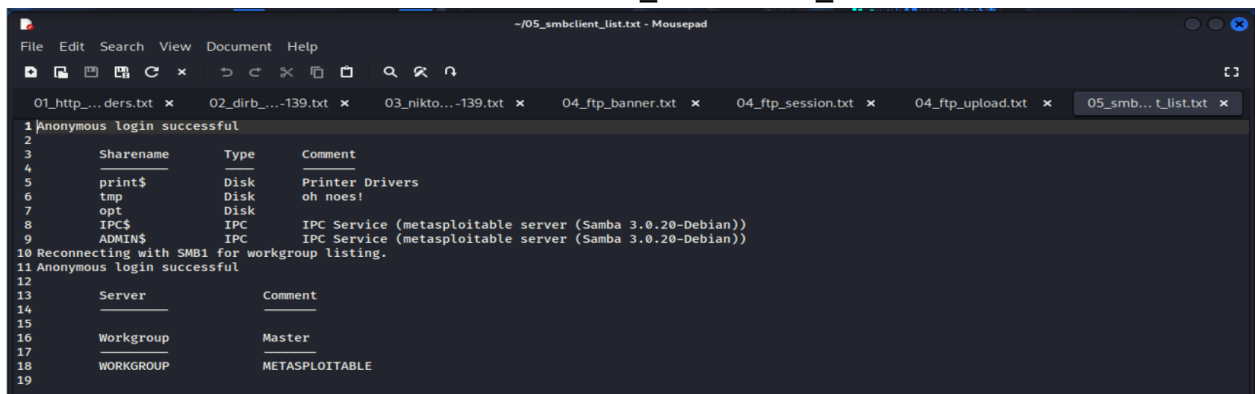
```
~/04_ftp_session.txt - Mousepad  
File Edit Search View Document Help  
01_http_headers.txt x 02_dirb_192-168-0-139.txt x 03_nikto_192-168-0-139.txt x 04_ftp_banner.txt x 04_ftp_session.txt x  
1 |Connected to 192.168.0.139.  
2 220 (vsFTPd 2.3.4)  
3 Name (192.168.0.139:kali): 331 Please specify the password.  
4 230 Login successful.  
5 Remote system type is UNIX.  
6 Using binary mode to transfer files.  
7 ?Invalid command.  
8 229 Entering Extended Passive Mode (|||36870|).  
9 150 Here comes the directory listing.  
10 226 Directory send OK.  
11 221 Goodbye.  
12
```

10. create local test file and put it to FTP → `04_ftp_upload.txt`



```
~/04_ftp_upload.txt - Mousepad  
File Edit Search View Document Help  
01_http_headers.txt x 02_dirb_192-168-0-139.txt x 03_nikto_192-168-0-139.txt x 04_ftp_banner.txt x 04_ftp_session.txt x 04_ftp_upload.txt x  
1 |Connected to 192.168.0.139.  
2 220 (vsFTPd 2.3.4)  
3 Name (192.168.0.139:kali): 331 Please specify the password.  
4 230 Login successful.  
5 Remote system type is UNIX.  
6 Using binary mode to transfer files.  
7 ?Invalid command.  
8 local: /tmp/ftptest/test.txt remote: /tmp/ftptest/test.txt  
9 229 Entering Extended Passive Mode (|||36321|).  
10 553 Could not create file.  
11 229 Entering Extended Passive Mode (|||32111|).  
12 150 Here comes the directory listing.  
13 226 Directory send OK.  
14 221 Goodbye.  
15
```

11. `smbclient -L //192.168.0.139 -N > 05_smbclient_list.txt`



```
~/05_smbclient_list.txt - Mousepad  
File Edit Search View Document Help  
01_http_headers.txt x 02_dirb_192-168-0-139.txt x 03_nikto_192-168-0-139.txt x 04_ftp_banner.txt x 04_ftp_session.txt x 04_ftp_upload.txt x 05_smbclient_list.txt x  
1 |Anonymous login successful  
2  
3 Sharename Type Comment  
4 print$ Disk Printer Drivers  
5 tmp Disk oh noes!  
6 opt Disk  
7 IPC$ IPC IPC Service (metasploitable server (Samba 3.0.20-Debian))  
8 ADMIN$ IPC IPC Service (metasploitable server (Samba 3.0.20-Debian))  
9  
10 Reconnecting with SMB1 for workgroup listing.  
11 Anonymous login successful  
12  
13 Server Comment  
14  
15 Workgroup Master  
16  
17 WORKGROUP METASPLOITABLE  
18  
19
```



12.enum4linux -a 192.168.0.139 > 05_enum4linux_192-168-0-139.txt

```
File Edit Search View Document Help
~/05_enum4linux_192-168-0-139.txt - Mousepad

01_http...rs.txt x 02_dir...39.txt x 03_nik...39.txt x 04_ftp...er.txt x 04_ftp...ion.txt x 04_ftp...ad.txt x 05_sm...list.txt x 05_en...139.txt x
1 | Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Thu Oct 30 11:58:22 2025
2
3 | [34m ===== ( [0m[32mTarget Information[0m[34m ) =====
4
5 | [0mTarget ..... 192.168.0.139
6 | RID Range ..... 500-550,1000-1050
7 | Username ..... ''
8 | Password ..... ''
9 | Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
10
11 | [34m ===== ( [0m[32mEnumerating Workgroup/Domain on 192.168.0.139[0m[34m ) =====
12
13 | [0m[33m
14 | [0m[32mGot domain/workgroup name: WORKGROUP
15 | [0m
16 | [34m ===== ( [0m[32mNbtstat Information for 192.168.0.139[0m[34m ) =====
17 | [0m
18 | [34m ===== ( [0m[32mSession Check on 192.168.0.139[0m[34m ) =====
19
20 | Looking up status of 192.168.0.139
21 | METASPLOITABLE <00> - B <ACTIVE> Workstation Service
22 | METASPLOITABLE <03> - B <ACTIVE> Messenger Service
23 | METASPLOITABLE <20> - B <ACTIVE> File Server Service
24 | .._MSBROWSE_ <01> - <GROUP> B <ACTIVE> Master Browser
25 | WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
26 | WORKGROUP <1d> - B <ACTIVE> Master Browser
27 | WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
28
29 | MAC Address = 00-00-00-00-00-00
30
31 | [34m ===== ( [0m[32mSession Check on 192.168.0.139[0m[34m ) =====
32
33 | [0m[33m
```

13.mysql --protocol=tcp -h 192.168.0.139 -u root --skip-ssl →
interactive (evidence in 06_mysql_attempt.txt)

```
File Edit Search View Document Help
~/06_mysql_attempt.txt - Mousepad

01_h...rs.txt x 02_d...9.txt x 03_n...9.txt x 04_f...er.txt x 04_f...on.txt x 04_f...ad.txt x 05_s...t.txt x 05_e...9.txt x 06_m...t.txt x
1 | ERROR 2026 (HY000): TLS/SSL error: wrong version number
2
```

14.psql -h 192.168.0.139 -p 5432 -U postgres -c '\l' >
07_pg_attempt.txt

```
File Edit Search View Document Help
~/07_pg_attempt.txt - Mousepad

01_...s.txt x 02_...t.txt x 03_...t.txt x 04_...f.txt x 04_...t.txt x 04_...t.txt x 05_...t.txt x 05_...t.txt x 06_...t.txt x 07_...t.txt x
1 | psql: error: connection to server at "192.168.0.139", port 5432 failed: SSL error: unsupported protocol
2 | This may indicate that the server does not support any SSL protocol version between TLSv1.2 and TLSv1.3.
3 | connection to server at "192.168.0.139", port 5432 failed: FATAL: password authentication failed for user "postgres"
4
```

15.nc -vz 192.168.0.139 3632 > 08_distcc_banner.txt 2>&1

```
File Edit Search View Document Help
~/08_distcc_banner.txt - Mousepad

01_...txt x 02_...txt x 03_...txt x 04_...txt x 04_...txt x 04_...txt x 05_...txt x 05_...txt x 06_...txt x 07_...txt x 08_...txt x
1 | metasploitable [192.168.0.139] 3632 (distcc) open
2
```



16. `sudo nmap -sV --script rmi-dumpregistry -p1099 192.168.0.139 -oN 09_rmi_nmap.txt`

```
1 # Nmap 7.95 scan initiated Thu Oct 30 12:16:16 2025 as: /usr/lib/nmap/nmap -sV --script rmi-dumpregistry -p1099 -oN 09_rmi_nmap.txt 192.168.0.139
2 Nmap scan report for metasploitable (192.168.0.139)
3 Host is up (0.00093s latency).
4
5 PORT      STATE SERVICE VERSION
6 1099/tcp  open  java-rmi GNU Classpath grmiregistry
7 MAC Address: 00:0C:29:EF:05:E4 (VMware)
8
9 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
10 # Nmap done at Thu Oct 30 12:16:23 2025 -- 1 IP address (1 host up) scanned in 7.37 seconds
11
```

17. `showmount -e 192.168.0.139 > 10_nfs_exports.txt`

```
1 Export list for 192.168.0.139:
2 / *
3
```

18. `sudo nmap --script vuln -p 21,22,23,80,111,139,445,3306,3632,5432,5900 192.168.0.139 -oN 13_nmap_vuln_scripts.txt`

```
1 # Nmap 7.95 scan initiated Thu Oct 30 12:23:05 2025 as: /usr/lib/nmap/nmap --script vuln -p 21,22,23,80,111,139,445,3306,3632,5432,5900 -oN 13_nmap_vuln_scripts.txt 192.168.0.139
2 Pre-scan script results:
3 | broadcast-avahi-dos:
4 |   Discovered hosts:
5 |     224.0.0.251
6 |   After NULL UDP avahi packet DoS (CVE-2011-1002).
7 |   Hosts are all up (not vulnerable).
8 |
```

8. Remediation & mitigation — actionable checklist

Immediate (P1): - Disable anonymous SMB logins and remove open tmp share or require authentication.

- Remove phpinfo.php and restrict phpMyAdmin to admin IPs or via VPN.
- Disable anonymous FTP and secure vsftpd; enforce accounts and disable write for anonymous.
- Upgrade Samba, Apache, MySQL, PHP, vsftpd to supported versions and apply security patches.

High (P2): - Replace Telnet with SSH; disable VNC or secure it with strong passwords and TLS wrappers.

- Disable or tightly restrict distcc and Java RMI; update or remove if not needed.
- Enforce DB authentication, use TLS with modern ciphers, and restrict DB listeners to local or trusted subnets.



Medium (P3): - Disable directory listing; enable X-Frame-Options and X-Content-Type-Options headers.

- Harden server configurations per CIS Benchmarks.

Long-term: - Implement patch management; add host-level IDS/monitoring; centralize logging to ELK/SIEM; regular vulnerability scans.

9. Notes & learning outcomes

- Gained **hands-on experience** in performing a full **Vulnerability Assessment and Penetration Testing (VAPT)** on a live target (Metasploitable2).
- Learned to use essential **Kali Linux tools** such as Nmap, Nikto, Dirb, Enum4linux, SMBClient, and Netcat for enumeration and scanning.
- Identified **open ports and running services** (FTP, SSH, HTTP, MySQL, SMB, etc.) and understood their security implications.
- Discovered **web vulnerabilities** such as directory listing, outdated software versions, phpinfo exposure, and missing security headers.
- Understood the risks of **misconfigurations** like anonymous FTP and SMB access that can lead to unauthorized data exposure.
- Observed the presence of **outdated and vulnerable software versions** (Apache 2.2.8, PHP 5.2, Samba 3.0.20) and their potential exploitation risks.
- Practiced **database enumeration** techniques using MySQL and PostgreSQL connections to identify weak or default credentials.
- Learned to interpret **Nmap vulnerability scripts** and correlate service versions with known CVEs.
- Gained insight into **documentation best practices** — recording commands, results, screenshots, and CVSS risk ratings systematically.
- Enhanced understanding of **risk assessment and prioritization** using CVSS scoring and risk matrices.
- Strengthened awareness of **defensive countermeasures** — disabling unused ports, enforcing password policies, and updating legacy software.
- Improved skills in **report writing** by summarizing technical findings into a structured, professional security report.
- Developed a complete workflow from **reconnaissance to reporting**, aligning with real-world cybersecurity assessments.

Report by ~Aliya.